Luiss
Libera Università Internazionale
degli Studi Sociali Guido Carli

Lab on NMAP and Vuln scanner

Data Privacy and Security

Data Science and Management (DASMA)

LUISS

Agenda

- What is Nmap
- Nmap examples
- Limits of Nmap
- Vulnerability scanners
- CVE / CVSS / Zero-day
- Internet-wide scanning
- Shodan demo
- Wrap-up

What is Nmap?

What is Nmap?

Nmap (**Network Mapper**) is an open-source tool used for:

- Network discovery
- Port scanning
- Service detection
- OS fingerprinting

What Can Nmap Do?

- Discover live hosts
- Identify open ports
- Detect running services
- Guess operating systems
- Run scripts (NSE)

Basic Scan

```
nmap scanme.nmap.org
```

Basic Scan

```
nmap scanme.nmap.org
```

```
Nmap scan report for XXXXXXX
Host is up (0.019s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT      STATE     SERVICE
22/tcp    open      ssh
25/tcp    open      smtp
53/tcp    open      domain
80/tcp    open      http
110/tcp   open      pop3
143/tcp   open      imap
443/tcp   open      https
465/tcp   open      smtps
587/tcp   open      submission
993/tcp   open      imaps
995/tcp   open      pop3s
```

Service Detection

```
nmap -sV scanme.nmap.org
```

Service Detection

```
nmap -sV scanme.nmap.org
```

```
Nmap scan report for XXXXXXX
Host is up (0.011s latency).
Not shown: 989 closed tcp ports (conn-refused)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 10.0p2 Debian 7 (protocol 2.0)
25/tcp  open  smtp     Postfix smtpd
53/tcp  open  domain   dnsmasq 2.92test21 (pi-hole)
80/tcp  open  http     nginx
110/tcp open  pop3     Dovecot pop3d
143/tcp open  imap     Dovecot imapd
443/tcp open  ssl/http nginx
465/tcp open  ssl/smtp Postfix smtpd
587/tcp open  smtp     Postfix smtpd
993/tcp open  imaps?
995/tcp open  pop3s?
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

What Nmap Does NOT Do Well

- No full vulnerability correlation
- Limited automation
- Requires manual analysis

What Nmap Does NOT Do Well

- No full vulnerability correlation
- Limited automation
- Requires manual analysis

> Does OpenSSH 10.0p2 Debian has any vulnerabilities?

What Nmap Does NOT Do Well

- No full vulnerability correlation
- Limited automation
- Requires manual analysis

> Does OpenSSH 10.0p2 Debian has any vulnerabilities?

> Does dnsmasq 2.92test21 has vulnerabilities?

What Nmap Does NOT Do Well

- No full vulnerability correlation
- Limited automation
- Requires manual analysis

> Does OpenSSH 10.0p2 Debian has any vulnerabilities?

> Does dnsmasq 2.92test21 has vulnerabilities?

But the real question is...

What Nmap Does NOT Do Well

- No full vulnerability correlation
- Limited automation
- Requires manual analysis

> Does OpenSSH 10.0p2 Debian has any vulnerabilities?

> Does dnsmasq 2.92test21 has vulnerabilities?

But the real question is...

> Is this host vulnerable?

Enter Vulnerability Scanners

Tools that go beyond Nmap and automatically do:

- Automated vulnerability detection
- Risk scoring
- Reporting dashboards

Enter Vulnerability Scanners

Tools that go beyond Nmap and automatically do:

- Automated vulnerability detection
- Risk scoring
- Reporting dashboards

Commercial Tools:

- Nessus
- Qualys
- Rapid7 InsightVM
- Intruder

Enter Vulnerability Scanners

Tools that go beyond Nmap and automatically do:

- Automated vulnerability detection
- Risk scoring
- Reporting dashboards

Commercial Tools:

- Nessus
- Qualys
- Rapid7 InsightVM
- Intruder

> Or Open Source tools: OpenVAS

What These Tools Do

1. Detect services (like Nmap)
2. Match them to vulnerabilities
3. Assign severity scores

CVE (Common Vulnerabilities and Exposures)

CVE

- Standardized vulnerability IDs
- Example: CVE-2024-12345
- The vulnerabilities are all public!

Managed by MITRE

CVSS (Scoring System)

Score	Severity
0–3	Low
4–6	Medium
7–8	High
9–10	Critical

Zero-Day vs N-Day

Zero-Day vs N-Day

Zero-day

- Unknown vulnerability
- No patch available

Zero-Day vs N-Day

Zero-day

- Unknown vulnerability
- No patch available

N-day

- Known vulnerability
- Patch exists

Internet-Wide Scanning

Platforms

Some platforms scan the entire Internet continuously:

- Shodan
- Censys
- ZoomEye

What They Index

- Open ports
- Services
- Banners
- Devices

What They Index

- Open ports
- Services
- Banners
- Devices

> If it is exposed to the Internet, it will be found

Common Risks

- Misconfigured services
- Default credentials
- Unpatched systems
- Shadow IT